勒索软件保护
ONTAP 9

NetApp
June 14, 2022

This PDF was generated from https://docs.netapp.com/zh-cn/ontap/anti-ransomware/index.html on June 14, 2022. Always check docs.netapp.com for the latest.

目录

勒索软件保护 1
反勒索软件概述 1
反勒索软件使用情形和注意事项 2
启用反勒索软件 4
默认情况下，在新卷中启用反勒索软件 6
暂停反勒索软件以从分析中排除工作负载事件 6
应对异常活动。 7
在发生攻击后还原数据 9
修改自动Snapshot副本的选项 10

勒索软件保护

反勒索软件概述

从 ONTAP 9.10.1 开始，反勒索软件功能使用 NAS （ NFS 和 SMB ）环境中的工作负载分析主动检测并警告可能指示勒索软件攻击的异常活动。

如果怀疑发生攻击、除了从计划的Snapshot副本中提供现有保护之外、反勒索软件还会创建新的Snapshot副本。

反勒索软件功能可通过以下许可证启用。

ONTAP 版本	许可证
ONTAP 9.11.1及更高版本	反勒索软件
ONTAP 9.10.1	MT_EK_Mgmt (多租户密钥管理)

- 如果您要升级到ONTAP 9.11.1或更高版本、并且系统上已配置反勒索软件保护、则无需购买新的反勒索软件许可证。对于新的反勒索软件配置、需要新的许可证。
- 如果您要从ONTAP 9.11.1或更高版本还原到ONTAP 9.10.1、并且您已使用反勒索软件许可证启用反勒索软件保护、则会看到一条警告消息、并且可能需要重新配置反勒索软件。 "了解如何还原反勒索软件保护"。

您可以使用 ONTAP 系统管理器或 ONTAP 命令行界面（ CLI ）按卷配置反勒索软件保护。

ONTAP 勒索软件保护策略

有效的勒索软件检测策略应包括多个保护层。

一个比喻是车辆的安全特性。您不希望依靠安全带等单一功能在意外事件中为您提供全面保护。安全袋，防抱死制动器和前向碰撞警告都是额外的安全功能，可以带来更好的结果。应以相同方式查看勒索软件保护。

虽然 ONTAP 包含 FPolicy ， Snapshot 副本， SnapLock 和 Active IQ 数字顾问等功能，可帮助防止勒索软件，但以下信息重点介绍 ONTAP 的机载反勒索软件功能以及机器学习功能。

要详细了解 ONTAP 的其他反勒索软件功能，请参见： "TR-4572 ：《 NetApp 解决方案 for 勒索软件》。"

ONTAP 反勒索软件检测到的内容

勒索软件攻击有两种：

1. 通过加密数据拒绝为文件提供服务。除非支付了勒索费用，否则攻击者将无法访问此数据。
2. 敏感专有数据被盗。攻击者威胁要将此数据释放到公有域，除非支付了勒索。

ONTAP 勒索软件保护解决了第一种类型，它采用了一种基于以下内容的反勒索软件检测机制：

1. 将传入数据标识为加密或纯文本。

2. 分析，用于检测
    - high data _entropy （评估文件中数据的随机性）
    - 使用数据加密时异常卷活动激增
    - 不符合正常扩展类型的扩展

> 任何勒索软件检测或预防系统都无法完全保证免遭勒索软件攻击的安全。虽然攻击可能会被检测不到，但如果防病毒软件无法检测到入侵， NetApp 勒索软件保护可作为一个重要的额外防御层。在对少量文件进行加密后，反勒索软件可以检测到大多数勒索软件攻击的蔓延，自动采取措施保护数据，并提醒您可疑攻击正在发生。

如何在勒索软件攻击后在 ONTAP 中恢复数据

如果怀疑发生攻击，系统将在该时间点创建卷 Snapshot 副本并锁定该副本。如果稍后确认此攻击，则可以将卷还原到此主动创建的快照，从而最大程度地减少数据丢失。

无法正常删除已锁定的 Snapshot 副本。但是，如果您稍后决定将此攻击标记为误报，则锁定的副本将被删除。

了解受影响的文件和攻击时间后，可以有选择地从各种 Snapshot 副本恢复受影响的文件，而不是简单地将整个卷还原到某个快照。

因此，反勒索软件基于经验证的 ONTAP 数据保护和灾难恢复技术构建，可应对勒索软件攻击。有关恢复数据的详细信息，请参见以下主题。

- "从 Snapshot 副本恢复（ System Manager ）"
- "从 Snapshot 副本还原文件（命令行界面）"
- "智能勒索软件恢复"

反勒索软件使用情形和注意事项

ONTAP 平台支持：

平台	可用开始...
ONTAP 内部部署	ONTAP 9.10.1
Cloud Volumes ONTAP	ONTAP 9.11.1
适用于 AWS 和 Google Cloud 的 Cloud Volume Services	不支持
Azure NetApp Files	不支持
ONTAP Select	不支持

合适的工作负载：

- NFS 存储上的数据库
- Windows 或 Linux 主目录

  由于用户可以使用在学习期间未检测到的扩展名创建文件，因此此工作负载很可能出现误报。

- 图像和视频

  例如，医疗保健记录和电子设计自动化（ Electronic Design Automation ， EDA ）数据。

不适合的工作负载：

- 文件创建或删除频率较高的工作负载（几秒内就有数十万个文件；例如，测试 / 开发工作负载）
- 反勒索软件功能取决于识别文件创建或删除活动异常激增的能力。如果应用程序本身是文件活动的源，则无法有效地将其与勒索软件活动区分开来
- 应用程序或主机对数据进行加密的工作负载防勒索软件功能取决于将传入数据区分为加密或未加密。如果应用程序本身正在对数据进行加密，则此功能的有效性将会降低。但是，根据文件活动（创建，删除和覆盖）和文件类型，此功能仍可正常工作。

不支持的系统配置：

- SAN 环境
- ONTAP S3 环境
- NFS 上的 VMDK

卷要求：

- 容量不足 100%
- 接合路径必须处于活动状态

不支持的卷类型：

- 使卷脱机
- 受限卷
- SnapLock 卷
- FlexGroup 卷
- FlexCache 卷（原始 FlexVol 卷支持反勒索软件功能，但缓存卷不支持此功能）
- SAN-only volumes
- 已停止 Storage VM 的卷
- Storage VM 的根卷
- 数据保护卷

反勒索软件的性能和频率注意事项

按吞吐量和峰值 IOPS 衡量，反勒索软件功能对系统性能的影响最小。反勒索软件功能的影响在很大程度上取决于卷工作负载。对于大多数典型或常见工作负载，建议使用以下配置限制：

工作负载特征	每个节点的建议卷限制	超出每节点卷限制时性能下降传递：**[*]**
读取密集型数据或数据可以压缩。	150	最大IOPS的4%
写入密集型、无法压缩数据。	60	最大IOPS的10%

密码：[*]无论添加的卷数是否超过建议的限制、系统性能均不会超过这些百分比。

由于反勒索软件分析按优先顺序运行，因此随着受保护卷数量的增加，对每个卷运行分析的频率也会降低。

检测到勒索软件时自动 **Snapshot** 副本的工作原理

为了尽可能获得最佳恢复点，一旦检测到异常文件活动，反勒索软件功能就会创建一个自动 Snapshot 副本。但是，反勒索软件功能不会立即标记警报；相反，在生成警报之前，需要运行分析并确认可疑活动与勒索软件配置文件匹配。此过程可能需要长达 60 分钟。如果分析确定活动不可疑，则不会生成警报，但自动创建的 Snapshot 副本会在文件系统上至少保留两天。

从ONTAP 9.11.1开始、您可以控制针对可疑勒索软件攻击自动生成的反勒索软件Snapshot副本的数量和保留期限。了解操作方法 "修改自动Snapshot副本的选项"。

启用反勒索软件

从 ONTAP 9.10.1 开始，可以在新卷或现有卷上启用反勒索软件保护。您首先要在学习模式下启用反勒索软件，在此模式下，系统会分析工作负载以确定正常行为特征，然后切换到主动模式，在主动模式下，系统会标记异常活动以供您评估。

您需要什么？ **#8217**；将需要什么

- 为 NFS 或 SMB （或这两者）启用的 Storage VM 。
- 已为您的ONTAP 版本安装正确的许可证。

ONTAP 版本	许可证
ONTAP 9.8-9.10.1	MT_EK_Mgmt (多租户密钥管理)
ONTAP 9.11.1及更高版本	反勒索软件

- 配置了客户端的 NAS 工作负载。
- 要保护的卷必须具有活动接合路径。
- 可选但建议： EMS 系统配置为发送电子邮件通知，其中包括反勒索软件活动通知。有关详细信息，请参见 "配置 EMS 事件以发送电子邮件通知"。

NetApp 反勒索软件功能包括一个初始学习期（也称为 " 试运行 " ），在此期间， ONTAP 系统将了解哪些文件扩展名有效，并使用分析后的数据来开发警报配置文件。在学习模式下运行反勒索软件并有足够时间评估工作负载特征后，您可以切换到主动模式并开始保护数据。反勒索软件会继续收集和分析数据以细化警报配置文件。

在学习期间，系统会自动学习已配置卷的工作负载特征，并执行特殊观察和模式分析。

建议学习时间为 30 天。虽然您可以随时从学习切换到主动模式，但提前切换可能会导致误报过多。

在 ONTAP 命令行界面中，您可以使用 security anti勒索 软件 volume workload-behavior show 命令显示迄今为止检测到的文件扩展名。但是，建议不要使用此工具缩短学习时间。

您可以在现有卷上启用勒索软件保护，也可以创建新卷并从头开始启用勒索软件保护。

> 在现有卷中，学习和活动模式仅适用于新写入的数据，而不适用于卷中已有的数据。系统不会扫描和分析现有数据，因为在为防勒索软件功能启用卷后，系统会根据新数据假设早期正常数据流量的特征。

在 ONTAP 命令行界面中，我们引入了一个新的命令系列来管理此功能： `sSecurity anti-ransafecurt volume` 。您也可以使用 `volume modify` 命令和 `-anti勒索 软件` 参数来管理此功能。

System Manager 操作步骤

1. 单击 * 存储 > 卷 * ，然后选择要保护的卷。
2. 在卷概述的安全性选项卡中，单击防勒索软件框中的 * 状态 * ，在学习模式下从已禁用切换到已启用。
3. 学习期结束后，将反勒索软件切换到主动模式。
   a. 单击 * 存储 > 卷 * ，然后选择已准备好进入活动模式的卷。
   b. 在卷概述的安全性选项卡中，单击反勒索软件框中的 * 切换到活动模式 * 。
4. 您始终可以在 " 反勒索软件 " 框中验证卷的反勒索软件状态。要显示所有卷的防勒索软件状态：在卷窗格中，单击 * 显示 / 隐藏 * ，然后确保已选中防勒索软件状态。

命令行界面操作步骤

1. 修改现有卷以在学习模式下启用勒索软件保护：

   s安全防勒索软件卷 `dry-run -volume` *`vol_name`* `-vserver` *`svm_name`*

   您还可以使用 `volume modify` 命令启用勒索软件：

   `volume modify -volume` *`vol_name`* `-vserver` *`svm_name`* `-anti-ransone-state dry-run`

   在 CLI 中，您还可以在配置数据之前创建一个启用了反勒索软件保护的新卷。

   `volume create -volume` *`vol_name`* `-vserver` *`svm_name`* `-aggregate` *`aggr_name`* `-size` *`nn`* `-anti-ransonve-state dry-run -junction-path /`*`path_name`*

   > 您应始终在最初处于空运行状态的情况下启用勒索软件。从活动状态开始，可能会导致误报报告过多。

2. 学习期结束后，修改受保护卷以切换到活动模式：

   s安全防勒索软件卷 `enable -volume` *`vol_name`* `-vserver` *`svm_name`*

   您也可以使用 modify volume 命令切换到活动模式：

   `volume modify -volume` *`vol_name`* `-vserver` *`svm_name`* `-anti-ransone-state active`

3. 验证卷的防勒索软件状态。

   s安全性反勒索软件卷显示

默认情况下，在新卷中启用反勒索软件

从 ONTAP 9.10.1 开始，您可以配置 Storage VM （ SVM ），以便在学习模式下默认为反勒索软件启用新卷。

您将需要什么

- 已为您的ONTAP 版本安装正确的许可证。

ONTAP 版本	许可证
ONTAP 9.11.1及更高版本	反勒索软件
ONTAP 9.8-9.10.1	MT_EK_Mgmt (多租户密钥管理)

默认情况下，系统会在禁用模式下使用反勒索软件创建新卷，但您可以在 System Manager 和 CLI 中更改此设置。默认情况下，在学习模式下，启用的卷会设置为反勒索软件。

System Manager 操作步骤

1. 单击 * 存储 > 存储 VM* ，然后选择用于默认防病毒的 Storage VM 。
2. 在 * 设置 * 选项卡中的 * 安全性 * 部分中，单击 在 * 反勒索软件 * 框中，选中此框可为 NAS 卷启用反勒索软件。

命令行界面操作步骤

1. 修改现有 SVM 以在新卷中默认启用反勒索软件： `vserver modify -vserver` *`svm_name`* `-anti -ranswere-default-volume-state dry-run`

   在 CLI 中，您还可以创建一个新的 SVM ，并为新卷默认启用反勒索软件。`vserver create -vserver svm_name -anti-ransweron-default-volume-state dry-run [`*`other parameters as needed`*`]`

暂停反勒索软件以从分析中排除工作负载事件

如果您预期会发生异常工作负载事件，您可以随时临时暂停并恢复反勒索软件分析。

您将需要什么

- 反勒索软件正在学习或主动模式下运行。

在防勒索软件暂停期间，不会记录任何事件，也不会对新写入执行任何操作。但是，分析操作仍会在后台对早期日志执行。

请勿使用反勒索软件禁用功能暂停分析。这样做会禁用卷上的反勒索软件，并且与所了解的工作负载行为相关的所有现有信息都将丢失。这需要重新开始学习。

System Manager 操作步骤

1. 单击 * 存储 > 卷 * ，然后选择要暂停反勒索软件的卷。
2. 在卷概述的安全性选项卡中，单击防勒索软件框中的 * 暂停防勒索软件 * 。

命令行界面操作步骤

暂停卷上的勒索软件保护：

s安全防勒索软件卷暂停 `-vserver` *`svm_name`* `-volume` *`vol_name`*

要恢复处理，请使用 resume 参数。

s安全防勒索软件卷恢复 `-vserver` *`svm_name`* `-volume` *`vol_name`*

应对异常活动。

当反勒索软件检测到受保护卷中的异常活动时，它会发出警告。您应评估此通知，以确定此活动是否预期且可接受，或者是否正在进行攻击。

您将需要什么

- 反勒索软件正在活动模式下运行。

如果检测到高数据容量，具有数据加密的异常卷活动以及异常文件扩展名的任意组合，则反勒索软件将显示可疑文件的列表。

发出警告后，您可以通过以下两种方式之一来标记文件活动：

- 误报

  您的工作负载应具有已标识的文件类型，可以忽略此文件类型。

- 潜在的勒索软件攻击

  确定的文件类型在工作负载中是意外的，应视为潜在攻击。

在这两种情况下，在更新和清除通知后将恢复正常监控；反勒索软件会记录您的评估结果，日志会使用新文件类型进行更新，并将其用于未来分析。但是，在发生可疑攻击时，您必须确定是否是攻击，如果是攻击，则对此进行响应，并在清除通知之前还原受保护的数据。有关详细信息，请参见 "如何从勒索软件攻击中恢复"。

如果还原了整个卷、则不会通知您要清除。

System Manager 操作步骤

1. 收到 " 异常活动 " 通知后，单击链接或导航到 * 卷 * 概述的 * 安全性 * 选项卡。

   警告将显示在事件窗口的概述窗格中。

2. 显示 " 检测到异常卷活动 " 消息时，请查看可疑文件。

   在 * 安全性 * 选项卡中，单击查看 * 可疑文件类型 * 。

3. 在 * 可疑文件类型 * 对话框中，检查每个文件类型并将其标记为 " 误报 " 或 " 潜在勒索软件攻击 " 。

如果选择此值 ...	执行此操作...
误报	单击 * 更新 * 和 * 清除可疑文件类型 * 以记录您的决策并恢复正常的反勒索软件监控。
潜在勒索软件攻击	应对攻击并还原受保护的数据。然后，单击 * 更新 * 和 * 清除可疑文件类型 * 以记录您的决定并恢复正常的反勒索软件监控。+如果还原了整个卷、则不需要清除任何可疑文件类型。

命令行界面操作步骤

1. 收到可疑勒索软件攻击的通知后，请验证此攻击的时间和严重性：

   `sSecurity anti-ranson`勒索 软件 `volume show -vserver` *`svm_name`* `-volume` *`vol_name`*

   示例输出：

   ```
   Vserver Name: vs0
   Volume Name: vol1
   State: enabled
   Attack Probability: moderate
   Attack Timeline: 9/14/2021 01:03:23
   Number of Attacks: 1
   ```

   您还可以检查 EMS 消息：

   `event log show -message-name callhome.arw.activity.seen`

2. 生成攻击报告并记下输出位置：

   `s`安全防勒索软件卷攻击 `generate-report -volume` *`vol_name`* `-dest-path` *`file_location /`*

   示例输出：

   `Report "report_file_vs0_vol1_14-08-2021_01-21-08" available at path "vs0 ： vol1/"`

3. 在管理客户端系统上查看报告。例如：

```
[root@rhel8 mnt]# cat report_file_vs0_vol1_14-09-2021_01-21-08

19  "9/14/2021 01:03:23"   test_dir_1/test_file_1.jpg.lckd
20  "9/14/2021 01:03:46"   test_dir_2/test_file_2.jpg.lckd
21  "9/14/2021 01:03:46"   test_dir_3/test_file_3.png.lckd`
```

4. 根据对文件扩展名的评估，执行以下操作之一：

   - 误报

     输入以下命令以记录您的决定—将新扩展添加到允许的扩展列表中—并恢复正常的反勒索软件监控： **反勒索软件卷攻击** `clear-suspect -vserver` *`svm_name`* `-volume` *`vol_name`* `[`*`extension identifiers`*`] -false-positive true`

     使用以下参数之一确定扩展名：` [-seq-no *intege*]` 可疑列表中文件的序列号。` （ -extension *text* ，… ） ]` 文件扩展名 ` -start-time *date_time* -end-time *date_time*]` 要清除的文件范围的开始和结束时间，格式为 "MM/DD/YYYY HH： MM： SS" 。

   - 潜在的勒索软件攻击

     应对攻击并还原数据。然后，输入以下命令记录您的决定并恢复正常的反勒索软件监控：

     反勒索软件卷攻击 `clear-suspect -vserver` *`svm_name`* `-volume` *`vol_name`* `[`*`extension identifiers`*`] -false-positive false`

     使用以下参数之一来确定扩展名：` （ -seq-no *intege*）` 可疑列表中文件的序列号 ` （ -extension *text* ，…） ]` 文件扩展名 ` -start-time *date_time* -end-time *date_time*]` 要清除的文件范围的开始和结束时间，格式为 "MM/DD/YYYY HH： MM： SS" 。

如果还原了整个卷、则不需要清除任何可疑文件类型。

在发生攻击后还原数据

当反勒索软件检测到潜在攻击时，系统会创建名为 "Anti 勒索软件 _backup" 的 Snapshot 副本。您可以从这些反勒索软件副本或其他 Snapshot 副本还原数据。

> 如果发生勒索软件攻击，您应联系 NetApp 支持部门，了解他们是否能够协助数据恢复。

您将需要什么

- 支持反勒索软件
- 来自潜在勒索软件攻击的报告

System Manager 操作步骤

1. 显示已确定为潜在攻击的卷中的 Snapshot 副本：单击 * 存储 > 卷 * ，选择卷，然后单击 Snapshot 副本选项卡。

2. 按照以下说明还原所需的副本："从 Snapshot 副本恢复"

命令行界面操作步骤

1. 显示在已确定为潜在攻击的卷中的 Snapshot 副本： `volume snapshot show -vserver *svm_name* -volume *vol_name*`
2. 按照以下说明还原所需的副本："从 Snapshot 副本还原文件"

修改自动Snapshot副本的选项

从ONTAP 9.11.1开始、您可以控制针对可疑勒索软件攻击自动生成的反勒索软件(ARW) Snapshot副本的数量和保留期限。

注：`vserver options`命令是一个隐藏命令。要查看手册页、请在`ONTAP` 命令行界面中输入`man vserver options`。

可以修改以下自动Snapshot副本选项：

arw.snap.max.count

指定在任何给定时间卷中可以存在的最大ARW Snapshot副本数。系统会删除旧副本、以确保ARW Snapshot副本总数不超过此指定限制。

arw.snap.create.interval.hours

指定ARW Snapshot副本之间的间隔(以小时为单位)。如果怀疑发生攻击、而先前创建的副本早于此指定间隔、则会创建一个新的Snapshot副本。

arw.snap.normal.retain.interval.hours

指定保留ARW Snapshot副本的持续时间(以小时为单位)。如果某个ARW Snapshot副本变为旧副本、则会删除在最新副本之前为达到此期限而创建的任何其他ARW Snapshot副本。任何ARW Snapshot副本都不能早于此持续时间。

arw.snap.max.retain.interval.days

指定可保留ARW Snapshot副本的最长持续时间(以天为单位)。如果卷上未报告攻击、则超过此持续时间的任何ARW Snapshot副本将被删除。

arw.snap.create.interval.hours.post.max.count

指定当卷已包含最大ARW Snapshot副本数时ARW Snapshot副本之间的间隔(以小时为单位)。达到最大数量后、将删除一个ARW Snapshot副本、以便为新副本腾出空间。使用此选项可以降低新的ARW Snapshot副本创建速度、以保留旧副本。如果卷已包含最大数量的ARW Snapshot副本、则此选项中指定的间隔将用于下次创建ARW Snapshot副本、而不是创建arw.snap.create.interval.hours。

arw.surge.snap.interval.days

指定两个ARW快速增长Snapshot副本之间的间隔(以天为单位)。如果IO流量激增、而上次创建的ARW Snapshot副本早于此指定间隔、则会创建新的ARW Snapshot喘振副本。此选项还指定保留ARW快速增长Snapshot副本的持续时间(以天为单位)。

命令行界面操作步骤

要显示当前所有ARW Snapshot副本设置、请输入：`vserver options -vserver *svm_name* arw*`

要显示选定的当前ARW Snapshot副本设置、请输入：`vserver options -vserver *svm_name*-option -name *arw_setting_name*`

要修改ARW Snapshot副本设置、请输入：`vserver options -vserver *svm_name*-option-name *arw_setting_name*-option-value *arw_setting_value*`

版权信息

版权所有©2022 NetApp、Inc.。保留所有权利。Printed in the U.S.版权所涵盖的本文档的任何部分不得以任何形式或任何手段复制、包括影印、录制、 磁带或存储在电子检索系统中—未经版权所有者事先书面许可。

Software derived from copyrighted NetApp material is subject to the following license and disclaimer:

本软件由NetApp按"原样"提供、不含任何明示或默示担保、包括但不限于适销性和特定用途适用性的默示担保、特此声明不承担任何责任。IN NO EVENT SHALL NETAPP BE LIABLE FOR ANY DIRECT, INDIRECT, INCIDENTAL, SPECIAL, EXEMPLARY, OR CONSEQUENTIAL DAMAGES (INCLUDING, BUT NOT LIMITED TO, PROCUREMENT OF SUBSTITUTE GOODS OR SERVICES; LOSS OF USE, DATA, OR PROFITS; OR BUSINESS INTERRUPTION) HOWEVER CAUSED AND ON ANY THEORY OF LIABILITY, WHETHER IN CONTRACT, STRICT LIABILITY, OR TORT (INCLUDING NEGLIGENCE OR OTHERWISE) ARISING IN ANY WAY OUT OF THE USE OF THIS SOFTWARE, EVEN IF ADVISED OF THE POSSIBILITY OF SUCH DAMAGE.

NetApp reserves the right to change any products described herein at any time, and without notice.NetApp assumes no responsibility or liability arising from the use of products described herein, except as expressly agreed to in writing by NetApp.The use or purchase of this product does not convey a license under any patent rights, trademark rights, or any other intellectual property rights of NetApp.

The product described in this manual may be protected by one or more U.S.patents, foreign patents, or pending applications.

RESTRICTED RIGHTS LEGEND: Use, duplication, or disclosure by the government is subject to restrictions as set forth in subparagraph (c)(1)(ii) of the Rights in Technical Data and Computer Software clause at DFARS 252.277-7103 (October 1988) and FAR 52-227-19 (June 1987).

商标信息

NetApp、NetApp标识和中列出的标记 http://www.netapp.com/TM 是NetApp、Inc.的商标。其他公司和产品名称可能是其各自所有者的商标。